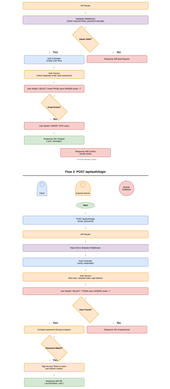
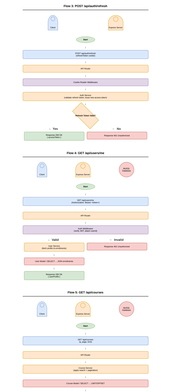
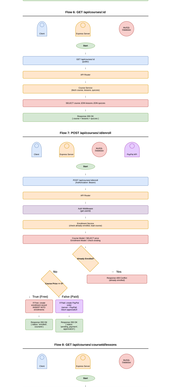
Flow 1: POST /api/auth/login



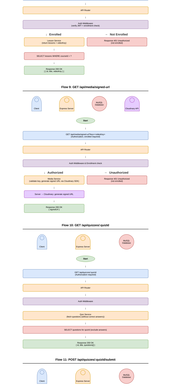
Flow 2: POST /api/auth/logo



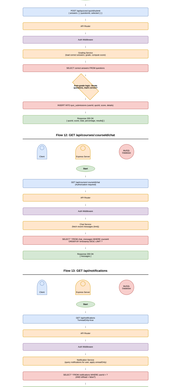
Flow 3: POST /api/auth/refresh



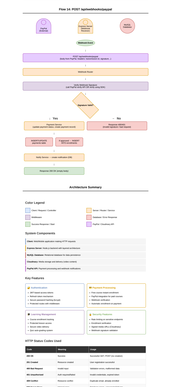
Flow 4: GET /api/auth/me



Flow 5: GET /api/courses



Flow 6: GET /api/courses/:id



Flow 7: POST /api/courses/:id/enroll

Flow 8: GET /api/courses/:id/curriculum

Flow 9: GET /api/enrollments/:id/ct

Flow 10: GET /api/progress/:id/ct

Flow 11: POST /api/progress/:id/ct/checkpoint

Flow 12: GET /api/progress/:id/ct/checkpoint

Flow 13: GET /api/admin/dashboard

Flow 14: GET /api/admin/users

Flow 15: PATCH /api/admin/users/:id/role

Flow 16: GET /api/admin/courses/:id/ct

Flow 17: GET /api/admin/ct-quotas

Flow 18: PATCH /api/admin/ct-quotas/:id

Architecture Summary

Color Legend

Client Request / Controller	Mongoose / Database Operation
Middleware	Validation / Error Response
Success Response / Start	Decision / Conditional Path

System Components

Client Mobile/Web application making HTTP requests

Express Server Node.js runtime with Express.js framework

Mongoose ODM Object Document Mapper for MongoDB schema validation

MongoDB Atlas Cloud-hosted MongoDB database

RazorPay API Payment processing and webhook verification

Key Features

Authentication
- JWT Bearer tokens (access + refresh)
- Refresh token rotation (max 5 per user)
- Account lockout (5 failed attempts, 2hr lockout)
- Rate limiting (5 req/min for auth endpoints)

Learning Management
- Course enrollment (free + paid)
- Curriculum structure
- Progress tracking with checkpoints
- HMAC-signed content URLs (time-limited)

Payment Processing
- Razorpay order creation
- Webhook signature verification
- Idempotent webhook handling
- Refund processing

Security Features
- Input validation (express-validator)
- Sanitization (prevent injection)
- Role-based access control (RBAC)
- Ownership verification

HTTP Status Codes Used

Code	Meaning	Usage
200 OK	Success	Successful GET, PATCH, PUT requests
201 Created	Resource created	User registration, enrollment
400 Bad Request	Invalid input	Validation errors, missing fields
401 Unauthorized	Not authenticated	Invalid credentials, expired token
403 Forbidden	Insufficient permissions	Inactive user, admin-only endpoint
404 Not Found	Resource missing	Invalid course, enrollment, checkpoint
423 Locked	Account locked	Too many failed login attempts
429 Too Many Requests	Rate limit exceeded	Exceeded 5 requests/minute limit
500 Internal Server Error	Server error	Database error, unexpected exception

Layered Architecture Pattern

Security Layers

1. **Rate Limiting** (express-rate-limit)
   - Auth endpoints: 5 requests/minute
   - Admin endpoints: 30 requests/minute
2. **Input Validation** (express-validator)
   - Email format, password length
   - Sanitization (prevent injection)
3. **Authentication** (JWT)
   - Bearer token extraction
   - Token expiry: 7 days
4. **Authorization** (RBAC)
   - Role check (student, instructor, admin)
   - Ownership verification
5. **Data Protection**
   - Password hashing (bcrypt, cost 12)
   - Exclude password from queries (select: false)
   - Sanitize error messages (no stack traces in production)